Access Control Policy

Document ID: E03
Department: Security
Owner: Rajesh Menon, Chief Information Security Officer
Version: v3.0
Effective Date: 2026-06-01
Classification: Confidential
Compartments: security

1. Purpose and scope

This policy sets how access to Aspire systems, data and facilities is granted, reviewed and removed. It applies to employees, contractors and service accounts across all offices and cloud environments. It supports our obligations under MAS Technology Risk Management Guidelines and ISO 27001. The Security team owns the policy and reviews it annually.

2. Principles

• Least privilege: users receive only the access required for their role and no more.

• Need to know: Confidential and Secret data requires explicit approval from the data owner.

• Separation of duties: no single person may both request and approve the same access, or both develop and release to production without review.

• Default deny: access not explicitly granted is refused.

• Traceability: every access decision is logged and logs are retained for 12 months online and 7 years archived.

3. RBAC model

Access is granted through roles, not to individuals. Each role maps to a bundle of permissions defined by the system owner and approved by Security. Roles are named by function, for example employee, engineer, security_engineer, account_manager, compliance_officer and legal_counsel. Document classification levels are 1 Public, 2 Internal, 3 Confidential and 4 Secret. Users can read a document only if they hold an allowed role, have sufficient clearance, and hold every compartment tag on the document, such as finance, legal or security. Direct permission assignment outside the role model needs a documented exception valid for 90 days at most.

4. Authentication

• Multi-factor authentication (MFA) is mandatory for all workforce accounts, with phishing-resistant FIDO2 keys required for engineers with production access and all administrators.

• SMS codes are not an acceptable MFA factor for privileged users.

• Passwords require at least 14 characters and are checked against breached password lists.

• Sessions to production tooling time out after 12 hours, and after 15 minutes of inactivity for privileged consoles.

5. Privileged access

Standing administrator rights are not permitted in production. Privileged access is granted just-in-time (JIT) through the access broker for a maximum of 4 hours, requires a ticket reference and approval by the system owner or a peer on the approver list, and is revoked automatically at

expiry. Sessions are recorded. Extension beyond 4 hours requires a fresh request. Service accounts use short-lived credentials rotated every 90 days or less and are owned by a named team.

6. Break-glass access

Break-glass accounts exist for emergencies where the access broker or identity provider is unavailable. Credentials are stored in a sealed vault requiring two authorised custodians. Use triggers an immediate alert to the Security on-call, and the use must be reviewed by the CISO within 1 business day. Credentials are rotated after every use. Break-glass accounts are tested twice a year.

7. Joiner, mover, leaver

Event	Requirement	SLA
Joiner	Baseline role provisioned on HR start date after manager approval	Within 1 business day of start
Mover	Previous role access removed and new role access granted	Within 3 business days of transfer
Leaver (voluntary)	All access disabled by HR-triggered workflow	Within 4 hours of last working time
Leaver (involuntary)	Immediate disablement coordinated by HR and Security	Before or at notification, maximum 1 hour
Contractor expiry	Accounts auto-expire at contract end date	Same day

8. Access recertification

Managers and system owners recertify access every quarter. Privileged and Confidential-data roles are reviewed by the data owner. Access that is not recertified within 14 days after the campaign closes is removed automatically. Results, including the number of revocations, are reported to the Risk Committee each quarter. Dormant accounts unused for 60 days are disabled, and deleted after 180 days.

9. Exceptions and enforcement

Exceptions need written approval from the CISO and are recorded in the risk register with an expiry date. Breaches of this policy may lead to disciplinary action. Suspected misuse must be reported to the Security team immediately.